

Benchmarking Security Features in Open-Source Healthcare Software Systems

Y.M.S. Tharaka*
Sabaragamuwa University of Sri
Lanka
Belihuloya, Sri Lanka
sachin@foc.sab.ac.lk

W.V.C. Maduwanthi
Sabaragamuwa University of Sri
Lanka
Belihuloya, Sri Lanka
chandima@foc.sab.ac.lk

L. Munasinghe
School of Computing, Engineering,
and Technology, Robert Gordon
University
Aberdeen, Scotland, United Kingdom
l.munasinghe@rgu.ac.uk

Abstract

Open-source Electronic Medical Record (EMR) systems require comprehensive security evaluation to ensure safe adoption in healthcare settings facing escalating cyber threats. With healthcare breaches costing USD 7.42 million on average per incident, the highest across all industries, robust EMR security is imperative. Despite their cost-effectiveness and growing adoption in resource-constrained environments, the security posture of open-source EMR platforms remains underexplored in academic literature. This paper presents a comprehensive benchmark of the security features of five widely used open-source EMR systems: OpenEMR, OpenMRS, GNU Health, Oscar EMR, and Bahmni, addressing critical gaps in healthcare-cybersecurity amid increasing attack surfaces. The study adopts a comparative, feature-based assessment methodology using a novel multidimensional security evaluation framework derived from the NIST Cybersecurity Framework (CSF), ISO/IEC 27001, and the HIPAA Security Rule. Five core dimensions are evaluated: authentication mechanisms, encryption and key management, interoperability security, role-based access control (RBAC), and regulatory compliance readiness. Empirical analysis reveals significant variation in authentication maturity and RBAC sophistication, alongside systemic weaknesses in application-level encryption, key management, and message-level interoperability security across all platforms. The findings highlight that while open-source EMRs provide extensible security foundations, achieving regulatory compliance and robust protection of Protected Health Information (PHI) depend heavily on deployment practices and organizational governance. This work offers actionable insights for healthcare organizations, policymakers, and developers to strengthen the secure adoption of open-source EMR systems.

Keywords

Electronic Medical Records, Healthcare Security, Open-Source Software, Regulatory Compliance, Healthcare IT

ACM Reference Format:

Y.M.S. Tharaka, W.V.C. Maduwanthi, and L. Munasinghe. 2026. Benchmarking Security Features in Open-Source Healthcare Software Systems. In *Workshop on Advances in Malware Analysis and Software Security (AMASS '26)*, June 01–05, 2026, Bangalore, India. ACM, New York, NY, USA, 10 pages. <https://doi.org/10.1145/3807501.3808238>



This work is licensed under a Creative Commons Attribution 4.0 International License. *AMASS '26, Bangalore, India*

© 2026 Copyright held by the owner/author(s).

ACM ISBN 979-8-4007-2651-4/2026/06

<https://doi.org/10.1145/3807501.3808238>

'26), June 01–05, 2026, Bangalore, India. ACM, New York, NY, USA, 10 pages. <https://doi.org/10.1145/3807501.3808238>

1 Introduction

Benchmarking is a systematic process of evaluating and comparing systems against a defined set of criteria to identify strengths, weaknesses, and areas for improvement[25]. In the context of healthcare information systems, benchmarking plays a critical role in supporting evidence-based decision-making, particularly when selecting Electronic Medical Record (EMR) platforms that must satisfy stringent requirements for security, reliability, and regulatory compliance. This study benchmarks the security capabilities of leading open-source EMR systems, focusing on how effectively they address confidentiality, integrity, availability, and compliance requirements in real-world healthcare environments.

EMR systems serve as central repositories for Electronic Protected Health Information (ePHI), supporting clinical decision-making, continuity of care, and operational efficiency. As healthcare organizations increasingly transition from paper-based workflows to digital systems, the security posture of EMR platforms becomes a critical determinant of patient safety and organizational resilience. Open-source EMR solutions have gained significant adoption due to their cost-effectiveness, customizability, and transparency, particularly in resource-constrained environments where proprietary systems may be prohibitively expensive [1]. Platforms such as OpenMRS and Bahmni are increasingly deployed in public-sector healthcare facilities, especially in low- and middle-income countries undergoing gradual health system digitization. Despite these benefits, the security implications of adopting open-source EMR systems remain insufficiently explored. While open-source transparency enables community-driven security improvements, it may also expose vulnerabilities to malicious actors if security controls are immature or poorly configured [10]. Furthermore, healthcare environments operate under strict regulatory obligations, including HIPAA and GDPR, which impose rigorous requirements on data protection, auditability, and access control. This creates a tension between rapid adoption of flexible open-source platforms and the need for demonstrable security assurance.

The urgency of addressing EMR security is underscored by the escalating cybersecurity threat landscape in healthcare. The sector has experienced a substantial rise in phishing attacks, with average breach costs reaching USD 7.42 million per incident, ranking highest among all industries for the fifteenth consecutive year [21][14]. Protected Health Information (PHI) has become a high-value target,

estimated to be worth 10–40 times more than credit card information on dark markets [9]. Recent large-scale breaches, such as those affecting Change Healthcare (190 million records) and Ascension Health (5.5 million records), highlight the catastrophic impact of inadequate security controls in healthcare information systems [16]. Additionally, breach notifications mandated under the HITECH Act have revealed over 5,000 healthcare breaches affecting more than 500 individuals each since 2009 [27].

From a practical perspective, the motivation for this research also stems from direct observations in clinical environments within developing countries. In many settings, clinicians continue to rely on fragmented or paper-based record systems, spending valuable consultation time searching for physical files. In some cases, patients are treated without access to complete medical histories, laboratory results, or medication records, increasing clinical risk and reducing patient confidence. While EMR adoption promises to address these challenges, insufficient attention to security can undermine trust and compromise patient safety. Existing academic studies have acknowledged the importance of open-source EMR systems but have largely emphasized functional or clinical maturity rather than security rigor. Comparative evaluations often lack systematic security benchmarking frameworks that align with healthcare-specific threat models and regulatory requirements. Consequently, healthcare organizations lack clear guidance when assessing the security readiness of open-source EMR platforms for deployment in sensitive clinical environments. This study addresses these gaps by conducting the first comprehensive comparative security benchmarking of five leading open-source EMR systems using a novel multidimensional evaluation framework. **The central research question guiding this work is:**

- How secure are open-source EMR systems within healthcare environments?
- How do their security features compare across key dimensions relevant to confidentiality, integrity, availability, and regulatory compliance?

2 Related Works

Prior studies provide the theoretical and practical foundations for evaluating security in open-source EMR platforms. Pertinent healthcare cybersecurity literature spans four principal domains: security frameworks and compliance standards, authentication and access control, encryption and key management, and interoperability security considerations.

2.1 Healthcare Security Frameworks and Compliances

Modern healthcare security frameworks align with established standards including NIST Cybersecurity Framework (CSF), ISO 27001, and HIPAA Security Rule requirements [24]. The NIST CSF provides six core functions (Prepare, Identify, Protect, Detect, Respond, Recover) specifically adapted for healthcare environments [19]. This framework has become increasingly important for healthcare organizations seeking to establish comprehensive cybersecurity programs that protect patient data while enabling clinical operations. ISO 27001 offers structured Information Security Management System (ISMS) implementation with particular relevance for healthcare

organizations managing sensitive patient data [15]. The standard's risk-based approach and comprehensive control set align well with healthcare's complex regulatory environment. Healthcare organizations can benefit from ISO 27001 certification by demonstrating systematic security management and continuous improvement processes [7]. **Healthcare-specific security requirements include administrative safeguards (security policies, training), physical safeguards (facility access controls, device controls), and technical safeguards (access control, audit logs, encryption) as mandated by HIPAA Security Rule [26].** The Security Rule establishes a flexible, scalable framework that allows covered entities to implement appropriate security measures based on their size, complexity, and capabilities.

The integration of these frameworks with open-source EMR evaluation remains underexplored in academic literature. While individual frameworks provide comprehensive guidance, their application to open-source healthcare software assessment requires adaptation to address unique characteristics of community-developed platforms including modular architectures, extension mechanisms, and distributed development models.

2.2 Authentication and Access Control in Healthcare

Authentication serves as the first line of defense for healthcare information systems. **Research has consistently identified weak authentication as a leading cause of healthcare data breaches [20].** Multi-factor authentication (MFA) has emerged as a critical control, with TOTP-based implementations providing practical balance between security and clinical workflow requirements [18]. Single Sign-On (SSO) through OAuth2 and OpenID Connect enables centralized identity management while reducing password fatigue for clinical users who must access multiple systems throughout their workflows [23]. Integration with enterprise identity providers such as Active Directory, Okta, and Keycloak facilitates consistent authentication policies across healthcare IT infrastructure. Role-Based Access Control (RBAC) implementation in healthcare contexts requires careful consideration of clinical workflows, organizational hierarchies, and regulatory requirements [28]. **Effective RBAC systems must balance the principle of least privilege against the reality of emergency access requirements and complex care team structures [11].**

2.3 Encryption and Key Management

Data encryption serves as essential defense-in-depth protection, safeguarding PHI in the event of unauthorized access or data breach [3]. However, encryption introduces operational complexity, performance considerations, and key management challenges that healthcare organizations must carefully navigate [6]. **The absence of application-level encryption in many healthcare systems places the burden of implementation on healthcare IT departments, often without adequate expertise or resources [22].** Key management represents a particularly challenging aspect, requiring secure generation, storage, rotation, and destruction of cryptographic keys throughout their lifecycle [2]. Transport Layer Security (TLS) has become ubiquitous for protecting data in transit, though proper implementation requires attention to protocol versions, cipher suite

selection, and certificate management [8]. Application-level encryption for stored data remains less common due to performance concerns and implementation complexity.

2.4 Healthcare Interoperability and Security

Healthcare interoperability standards including HL7, FHIR, and DICOM enable critical health information exchange between disparate systems [4]. However, interoperability introduces security challenges including authentication of external systems, authorization of data access, and protection of PHI during transmission [17]. FHIR's REST-based architecture has gained significant adoption due to its modern design and developer-friendly approach [13]. However, securing FHIR APIs requires careful implementation of OAuth2, proper scope definition, and consideration of patient consent directives [12]. The transition from document-based exchange (CDA/CCD) to API-based interoperability fundamentally changes the security threat model and required controls [5].

2.5 Analysis and Discussion

The reviewed literature demonstrates considerable advancement in healthcare cybersecurity across key domains, including security frameworks (NIST CSF, ISO 27001, HIPAA), authentication and access control mechanisms, encryption approaches, and interoperability standards. These studies provide well-established theoretical and procedural foundations for securing healthcare information systems. However, several limitations are evident. Prior research predominantly addresses isolated security components rather than conducting comprehensive evaluations of complete EMR systems. Encryption-related studies largely emphasize conceptual or best-practice models, with limited investigation into their practical implementation within open-source EMR platforms. Similarly, interoperability research tends to focus on functional data exchange, with insufficient attention to end-to-end security considerations such as message-level protection.

A significant gap in the existing body of knowledge is the absence of systematic, comparative security benchmarking frameworks tailored to open-source EMR systems. Furthermore, limited consideration is given to the architectural and operational characteristics of open-source platforms in existing security assessments. This study addresses these limitations by proposing a structured, multidimensional benchmarking framework that enables a comparative evaluation of leading open-source EMR systems in alignment with established healthcare security standards. The proposed approach extends existing literature by shifting the focus from isolated security mechanisms to holistic, system-level security assessment.

3 Methodology

This study conducts a systematic, documentation-based security feature benchmarking of leading open-source electronic medical record (EMR) systems, evaluating the security capabilities across five standardized dimensions derived from NIST Cybersecurity Framework, ISO 27001, and HIPAA Security Rule.

3.1 System Selection

The study focuses on five open-source EMR platforms chosen based on their popularity. OpenEMR¹ is a comprehensive EMR and practice management system widely deployed globally, particularly in outpatient settings, and represents a mature, feature-rich system with strong community support. OpenMRS² is a modular medical record platform designed initially for resource-limited settings and large-scale public health implementations, emphasizing extensibility and configurability through modules. Bahmni³ builds on OpenMRS and integrates hospital information system components and laboratory systems, representing a composite architecture used in several low- and middle-income countries. GNU Health⁴ is a Python-based system focused on public health and hospital information management and built on the Tryton framework, offering a distinct architectural approach. Oscar EMR⁵ is a Canadian-developed open-source EMR focused on primary care practice management, with substantial deployment in Canadian clinics.

Although the selected EMR systems are widely adopted and representative of leading open-source solutions, the system selection was primarily based on popularity to ensure relevance and real-world adoption. However, this approach may introduce selection bias, as less popular or emerging EMR systems were not included, which may limit the generalizability of the findings. Furthermore, the exclusive focus on open-source systems constrains the applicability of the results to proprietary EMR solutions, which may adopt different security architectures and controls. In addition, the study relies on documentation-based analysis, which may not fully reflect real-world deployment configurations or runtime security behavior.

3.2 Assessment Framework Development

The security assessment framework is organized around five core dimensions relevant to the effective evaluation of information systems and aligned with healthcare security and privacy requirements derived from NIST CSF, ISO 27001, and HIPAA Security Rule. The first dimension, authentication security, examines how each platform verifies user identity and manages authenticated sessions, including database authentication mechanisms and password hashing algorithms, support for multi-factor authentication (MFA), integration with enterprise identity providers through LDAP or Active Directory, support for OAuth2 and OpenID Connect for Single Sign-On, and session management policies including timeouts and auto-logout. The second dimension, encryption protocols, evaluates the protection of data at rest and in transit, focusing on the presence or absence of application-level encryption for PHI, reliance on database-level or filesystem-level encryption configurations, TLS configuration requirements, and the existence of any application-level key management capabilities. The third dimension, interoperability security, addresses how platforms secure health information exchange, including support for HL7, FHIR, DICOM, and CDA/CCD standards, API authentication mechanisms, use of

¹<https://www.open-emr.org/>

²<https://openmrs.org/>

³<https://www.bahmni.org/>

⁴<https://www.gnuhealth.org/>

⁵<https://fam.med.mcmaster.ca/oscar-emr/>

OAuth2 or token-based access control, and any message-level security features. The fourth dimension, role-based access control, analyzes RBAC models, including role granularity, permission expressiveness, the ability to support least privilege, emergency access mechanisms, and suitability for complex organizational structures. The fifth dimension, regulatory compliance, examines technical controls and documentation supporting HIPAA, GDPR, and related frameworks, including audit trail coverage, logging capabilities, breach notification support, data subject rights handling, and the degree to which systems provide compliance-oriented guidance or templates to implementers. Table 1: Security Assessment Dimensions and Evaluation Criteria.

3.3 Analysis Method

This research adopts a comparative model for the assessment of the security features in open-source healthcare software. In the comparative model, the comparison is made feature by feature and involves the assessment of authentication processes, encryption processes, interoperability security, RBAC complexity, and compliance features in the five open-source healthcare software platforms chosen for the research.

4 Results

The security benchmarking results for five open-source EMR systems across authentication mechanisms, encryption and key management, interoperability security, role-based access control (RBAC), and regulatory compliance readiness are shown in Tables 1.

4.1 Authentication Security Assessment

Authentication capabilities vary significantly across platforms, reflecting different development priorities and maturity levels, as summarized in Table 2. OpenEMR demonstrates the most comprehensive implementation, featuring native TOTP-based two-factor authentication compatible with Google Authenticator, Authy, and FreeOTP. Users scan QR codes for setup and enter rotating six-digit codes alongside passwords. The system employs bcrypt hashing through the users_secure table, providing strong resistance against rainbow table and brute-force attacks with configurable work factors. LDAP/Active Directory integration enables centralized identity management while preserving OpenEMR role assignments, and OAuth2/OpenID Connect support facilitates SSO with Keycloak, Okta, Google, and Azure AD. **HIPAA-compliant session management** includes configurable timeouts and auto-logout features, complemented by robust password policies enforcing complexity, expiration, and history requirements.

OpenMRS and Bahmni provide solid modular authentication foundations with salted and hashed password storage using industry-standard algorithms. While core platforms lack native MFA, organizations can implement it through dedicated modules or external SSO integration, reflecting OpenMRS's extensible architecture. LDAP authentication via modules enables credential verification against directory servers while maintaining internal privilege management. OAuth2 support through login modules enables SSO with enterprise identity providers. Session management creates secure tokens with configurable inactivity timeouts, and password policies

support minimum length, expiration, and lockout, with advanced complexity rules available through the Password Policy module.

Oscar EMR offers strong authentication in modern builds, featuring TOTP-based 2FA compatible with standard authenticator applications and SHA-256 password hashing. Administrators can enforce 2FA organization-wide or for specific roles. Configurable password policies include complexity requirements, expiration periods, and reuse prevention. While LDAP/Active Directory and OAuth2/OIDC integration require custom reverse-proxy implementations rather than native support, session management provides HIPAA-compliant auto-logout and configurable timeouts.

GNU Health presents the weakest authentication posture, relying on basic Tryton framework authentication with username/password credentials stored as hashed values. Older versions used SHA-1 hashing while newer Tryton implementations employ stronger algorithms, though specifics vary by deployment. Native MFA and OAuth2/OpenID Connect support are absent, requiring external SSO solutions like Keycloak. LDAP integration exists through Tryton modules but remains non-standard. Password policies are limited to minimum length requirements without native complexity enforcement or history tracking.

4.2 Encryption Protocol Analysis

A critical finding emerges from the encryption analysis: **all five platforms demonstrate universal weaknesses in encryption implementation, representing a fundamental architectural gap across the open-source EMR ecosystem**, as detailed in Table 3. No system provides built-in, application-level field-level encryption for Protected Health Information. OpenEMR, OpenMRS, Oscar EMR, and Bahmni store PHI unencrypted in MySQL, MariaDB, or PostgreSQL databases by default, while GNU Health similarly stores data unencrypted in PostgreSQL. **This design decision shifts the entire encryption burden to healthcare IT departments**, requiring manual configuration of Transparent Data Encryption (TDE), InnoDB tablespace encryption, PostgreSQL pgcrypto extensions, or operating system-level full-disk encryption solutions such as LUKS or BitLocker.

File attachments including clinical documents, diagnostic images, and scanned records, remain unencrypted across all platforms, stored directly on filesystems without application-level protection. Uploaded documents require either encrypted filesystem implementations or custom development to achieve confidentiality. The practical implication of this universal deficiency proves severe: server compromise or backup theft results in complete PHI exposure without additional protective layers. **This configuration dependency contradicts HIPAA Security Rule** addressable specifications recommending data-at-rest encryption.

All platforms support HTTPS/TLS for protecting data in transit through web interfaces and API communications, requiring proper Apache or Nginx configuration with valid certificates and modern TLS versions (1.2/1.3). **However, REST and SOAP API endpoints, along with HL7 and FHIR messages, rely entirely on transport-layer security without application-level encryption or message-level protection.** This hop-by-hop security model creates risk in complex network environments where intermediaries terminate TLS connections.

Table 1: Comparative Security Benchmarking of Open-Source EMR Systems

EMR System	Authentication	Encryption	Interoperability Security	RBAC Security	Compliance Adoption
OpenEMR	Strong (2FA, policies)	Moderate (TLS, DB configurable)	Moderate (HL7, limited FHIR)	Strong (fine-grained modules)	Strong (HIPAA docs, admin config)
OpenMRS	Moderate (modular LDAP)	Moderate (TLS, modular)	Strong (HL7, FHIR, OpenHIM)	Strong (granular, modular)	Moderate (HIPAA/GDPR via modules)
GNU Health	Weak (basic login)	Weak (TLS only)	Moderate (HL7, DICOM)	Moderate (module-level)	Weak (manual compliance)
OSCAR EMR	Strong (2FA, policies)	Moderate (TLS, DB configurable)	Moderate (HL7, FHIR plugins)	Strong (fine-grained modules)	Strong (HIPAA support)
Bahmni	Moderate (modular LDAP)	Moderate (TLS, modular)	Strong (HL7, FHIR, OpenHIM)	Strong (granular, modular)	Moderate (inherits OpenMRS)

Table 2: Authentication Features in Open-Source EMR Systems

Authentication Feature	OpenEMR	OpenMRS	GNU Health	OSCAR EMR	Bahmni
Username and Password Authentication	Supported	Supported	Supported	Supported	Supported
Password Hashing Algorithm	bcrypt	Salted and configurable	Basic hashing	SHA-256	Salted hashing (OpenMRS-based)
Multi-Factor Authentication (MFA / 2FA)	Native support (TOTP-based)	Available through modules	Not supported natively	Native support (TOTP-based)	Available through modules
LDAP / Active Directory Integration	Supported	Supported via modules	Limited support	External or proxy-based integration	Supported via modules
OAuth2 / OpenID Connect (Single Sign-On)	Supported	Supported via modules	Not supported	Supported via external integration	Supported
Session Timeout and Auto Logout	Configurable and enforced	Configurable	Basic session handling	Configurable and enforced	Configurable
Password Policy Enforcement	Strong	Moderate	Basic	Strong (complexity and expiration)	Moderate
Account Lockout and Brute-force Protection	Supported	Available through modules	Not supported	Supported	Available through modules

Key management represents an additional critical operational challenge, as no platform except OSCAR EMR provides built-in capabilities for key generation, rotation, escrow, or lifecycle management. Database encryption keys remain managed by underlying database engines while file encryption depends on operating system

mechanisms, lacking application-level orchestration, monitoring, or centralized control. This architectural limitation complicates compliance with NIST SP 800-57 key management guidelines emphasizing regular rotation, secure storage, access auditing, and controlled destruction.

Table 3: Encryption Features in Open-Source EMR Systems

Encryption Feature	OpenEMR	OpenMRS	GNU Health	OSCAR EMR	Bahmni
Data Encryption at Rest (Application-level)	Not supported natively	Not supported natively	Not supported natively	Not supported natively	Not supported natively
Database-level Encryption Support	Supported via DB configuration	Supported via DB configuration	Supported via DB configuration	Supported via DB configuration	Supported via DB configuration
File and Attachment Encryption	Not supported natively	Not supported natively	Not supported natively	Not supported natively	Not supported natively
Transport Layer Security (TLS / HTTPS)	Supported (TLS 1.2/1.3 via web server)	Supported (TLS via web server)	Supported (TLS via web server)	Supported (TLS via web server)	Supported (TLS via web server)
API Encryption (FHIR / REST / HL7)	Secured via TLS	Secured via TLS	Secured via TLS	Secured via TLS	Secured via TLS
Message-level Encryption (HL7 / FHIR payloads)	Not supported	Not supported	Not supported	Not supported	Not supported
Cryptographic Key Management	Not supported at application level	Not supported at application level	Not supported at application level	Limited (external management)	Not supported at application level
Key Rotation and Lifecycle Management	Not supported	Not supported	Not supported	Not supported	Not supported
Reliance on External Encryption Controls	High (DB / OS-level encryption required)	High	High	High	High

4.3 Interoperability Security Evaluation

Healthcare interoperability security varies significantly based on standards support and API security sophistication, as summarized in Table 4. OpenMRS and Bahmni demonstrate the strongest capabilities, supporting comprehensive HL7 and FHIR implementations through modules alongside OpenHIM integration. OpenHIM functions as an enterprise service bus providing secure routing, transformation, orchestration, and centralized authentication/authorization for health information exchange. OAuth2 token-based API authentication enables proper scope control and lifecycle management, while TLS/HTTPS protects transmission. However, even these advanced platforms rely on transport encryption without native message-level protection.

OpenEMR supports HL7 messaging with limited FHIR capabilities, securing APIs through HTTPS/TLS and available OAuth2/OpenID Connect authentication. CCD/CDA document exchange enables secure clinical document sharing, though HL7 messages lack encryption beyond transport security. Oscar EMR provides HL7 support with FHIR via plugins and configurable OAuth2 for REST APIs, remaining heavily TLS-dependent. GNU Health offers HL7 and DICOM support with limited FHIR exposure and basic API security, requiring significant administrative effort for secure configuration. A universal limitation persists across all platforms: the complete absence of message-level encryption or signing for interoperability

standards. HL7 and FHIR payloads transmitted between systems depend entirely on TLS confidentiality protection, creating exposure risks in multi-hop network scenarios or when intermediaries terminate encryption.

4.4 Role-Based Access Control Assessment

RBAC implementation sophistication varies considerably, carrying important implications for organizational security posture and administrative complexity. These comparative capabilities are presented in Table 5. OpenEMR delivers comprehensive built-in role and privilege systems with standard healthcare roles (Administrator, Physician, Nurse, Clerk, Lab Technician) and fine-grained module-level permissions covering patients, billing, prescriptions, and labs. Custom roles and per-user permission assignments enable organizational flexibility while supporting HIPAA least privilege and need-to-know principles. OpenMRS and Bahmni provide highly sophisticated privilege frameworks where roles map to granular view/edit/delete operations across patients, encounters, observations, and orders. Modular architecture enables privilege extension, supporting complex enterprise deployments with sophisticated hierarchies and care delivery models. GNU Health implements role and group-based access control suitable for small-to-medium deployments, though per-patient access granularity remains limited compared to more advanced platforms. Oscar EMR offers strong

Table 4: Interoperability Security Features in Open-Source EMR Systems

Interoperability Feature	Security	OpenEMR	OpenMRS	GNU Health	OSCAR EMR	Bahmni
HL7 Messaging Support		Supported	Supported	Supported	Supported	Supported
FHIR API Support		Limited support	Supported	Limited support	Supported via plug-ins	Supported
DICOM Integration		Limited	Limited	Supported	Limited	Limited
API Authentication Mechanism		OAuth2 / OpenID Connect	OAuth2 (via modules)	Basic authentication	OAuth2 (via plugins or proxy)	OAuth2
Token-Based Access Control		Supported	Supported	Limited	Supported	Supported
Transport Layer Security for Interoperability		Secured via TLS	Secured via TLS	Secured via TLS	Secured via TLS	Secured via TLS
Message-Level Encryption (HL7 / FHIR payloads)		Not supported	Not supported	Not supported	Not supported	Not supported
Message Integrity and Digital Signatures		Not supported	Not supported	Not supported	Not supported	Not supported
External Interoperability Gateway Support (e.g., OpenHIM)		Limited	Supported	Not supported	Not supported	Supported
Fine-Grained API Scope Control		Moderate	Strong	Weak	Moderate	Strong

configurable RBAC with fine-grained module permissions analogous to OpenEMR, accommodating diverse organizational structures.

4.5 Regulatory Compliance Analysis

Compliance support differs substantially across platforms, influencing regulatory risk exposure and implementation costs, with comparative capabilities detailed in Table 6. OpenEMR explicitly targets HIPAA compliance through dedicated documentation, comprehensive audit trails tracking user activity and patient record access, granular RBAC enforcing least privilege, and configurable encryption controls. Oscar EMR provides comparable HIPAA-supportive features including audit logging and TLS protection, though administrators must actively enable and monitor controls. OpenMRS, GNU Health, and Bahmni support HIPAA compliance through configuration rather than explicit certification. OpenMRS/Bahmni offer granular RBAC and audit modules alongside configurable encryption, while GNU Health provides basic features requiring extensive manual implementation. GDPR compliance presents greater challenges across all platforms, demanding consent management, data subject rights handling, and privacy-by-design capabilities largely absent from core distributions. OpenMRS provides some modular GDPR support, but all systems require substantial administrative effort for full compliance.

5 Discussion

The results presented in this study provide a structured comparative view of how five widely deployed open-source EMR systems address security requirements across authentication, encryption, interoperability security, role-based access control (RBAC), and regulatory compliance. The tables in the Results section collectively illustrate not only the presence or absence of security features, but also the relative maturity and deployment readiness of each platform. By benchmarking these systems side by side, this work highlights practical differences that are often obscured in feature-centric or functionality-focused evaluations.

The authentication benchmarking shows a clear stratification among platforms. OpenEMR and OSCAR EMR consistently score highest, demonstrating strong native support for two-factor authentication, configurable password policies, and session management controls. In contrast, OpenMRS and Bahmni exhibit moderate authentication maturity, relying heavily on modular extensions and external identity providers to achieve comparable security levels. GNU Health ranks lowest, as reflected in the tables by its lack of native MFA, limited password policy enforcement, and reliance on basic framework-level authentication. These results indicate that authentication security is uneven across open-source EMRs and highly dependent on architectural maturity and community investment.

Encryption benchmarking reveals the most significant and consistent weakness across all evaluated platforms. None of the EMRs

Table 5: RBAC Security Features in Open-Source EMR Systems

RBAC Security Feature	OpenEMR	OpenMRS	GNU Health	OSCAR EMR	Bahmni
Role-Based Access Control Model	Fully implemented	Fully implemented	Implemented	Fully implemented	Fully implemented
Predefined Healthcare Roles	Supported	Supported	Limited	Supported	Supported
Custom Role Creation	Supported	Supported	Supported	Supported	Supported
Granularity of Permissions	Fine-grained (module and action level)	Fine-grained (privilege-based)	Moderate (role and group level)	Fine-grained (module and action level)	Fine-grained (privilege-based)
Support for Least Privilege Principle	Strong	Strong	Moderate	Strong	Strong
User-to-Role Assignment Flexibility	High	High	Moderate	High	High
Emergency / Break-Glass Access	Limited	Limited (module-based)	Not supported	Limited	Limited (module-based)
Context-Aware Access (location, time, patient context)	Limited	Moderate	Limited	Limited	Moderate
Audit Logging of Access Control Decisions	Supported	Supported	Basic	Supported	Supported
Suitability for Large / Multi-Site Deployments	High	High	Low to Moderate	High	High

provide native application-level encryption for data at rest or file attachments, and all rely on external database- or operating-system-level controls. While TLS support for data in transit is universally available, message-level encryption and integrated cryptographic key management are entirely absent. This uniform pattern highlights a systemic gap in the open-source EMR ecosystem rather than isolated product limitations. The benchmarking results therefore indicate that encryption is not a differentiating factor among the selected EMRs, but rather a shared architectural challenge that must be addressed externally by deploying organizations.

Interoperability security benchmarking demonstrates clearer differentiation. OpenMRS and Bahmni consistently rank highest due to their comprehensive HL7 and FHIR support combined with OpenHIM-based interoperability gateways and OAuth2-based API security. OpenEMR and OSCAR EMR occupy a middle position, offering HL7 and limited or plugin-based FHIR support with transport-layer protection. GNU Health remains comparatively weaker, with limited API security mechanisms. However, these results reveal a universal limitation: no platform supports message-level encryption or digital signatures for HL7 or FHIR payloads. This finding indicates that while interoperability functionality varies significantly, security controls for exchanged data remain largely transport-dependent across all platforms.

RBAC benchmarking highlights stronger overall maturity compared to other security dimensions. OpenEMR, OpenMRS, Bahmni, and OSCAR EMR all demonstrate fine-grained role and privilege models suitable for complex healthcare workflows and multi-site deployments. GNU Health provides basic role and group-based

access control but lacks the granularity required for large-scale environments. The results further show that emergency access, context-aware authorization, and advanced governance features remain limited across most systems, suggesting that RBAC effectiveness depends not only on feature availability but also on careful administrative design and ongoing management.

Regulatory compliance benchmarking reveals that OpenEMR and OSCAR EMR offer the strongest readiness, supported by explicit HIPAA-focused documentation, comprehensive audit logging, and configurable safeguards. OpenMRS and Bahmni demonstrate moderate readiness, enabling compliance primarily through configuration and modular extensions rather than default implementations. GNU Health consistently ranks lowest due to limited logging, documentation, and compliance-oriented tooling. Importantly, the results collectively reinforce that none of the platforms provide turnkey compliance; instead, compliance emerges as an outcome of both software capabilities and organizational practices.

Overall, by systematically comparing security capabilities across widely deployed open-source EMR platforms, the results provide actionable insights into how different systems address core security requirements in practice. They highlight where platforms offer strong native support, where security depends on modular extensions, and where organizations must implement compensating controls externally. These insights are directly relevant to healthcare organizations evaluating EMR platforms, policymakers assessing the feasibility of open-source adoption in regulated environments, and developers seeking to prioritize security enhancements within open-source EMR ecosystems.

Table 6: Regulatory Compliance Features in Open-Source EMR Systems

Regulatory Compliance Feature		OpenEMR		OpenMRS		GNU Health	OSCAR EMR		Bahmni	
HIPAA-Oriented Safeguards	Technical	Strong	native support	Supported	through configuration	Limited support	Strong	native support	Supported	through configuration
Audit Trail and Activity Logging		Comprehensive and configurable		Comprehensive (module-based)		Basic logging	Comprehensive and configurable		Comprehensive (inherits OpenMRS)	
Access Logging for PHI		Supported		Supported		Limited	Supported		Supported	
Data Integrity and Tamper Detection		Partial (logging-based)	(logging-based)	Partial (logging-based)	(logging-based)	Limited	Partial (logging-based)	(logging-based)	Partial (logging-based)	(logging-based)
Breach Detection and Incident Support		Limited (manual processes)		Limited (manual processes)		Not explicitly supported	Limited (manual processes)		Limited (manual processes)	
GDPR Readiness (Consent, Data Subject Rights)		Limited		Partial (module-based)		Limited	Limited		Partial (inherits OpenMRS)	
Data Retention and Deletion Controls		Supported through configuration		Supported through configuration		Limited	Supported through configuration		Supported through configuration	
Security Documentation and Implementation Guidance		Extensive HIPAA-focused documentation		Moderate community documentation		Limited documentation	Moderate HIPAA-focused documentation		Moderate (OpenMRS-based)	
Compliance Dependency on Organizational Policies		Moderate		High		High	Moderate		High	
Overall Compliance Readiness		High		Moderate		Low	High		Moderate	

6 Conclusion

This study presented a comparative security benchmarking of five widely used open-source EMR systems—OpenEMR, OpenMRS, GNU Health, OSCAR EMR, and Bahmni—across authentication, encryption, interoperability security, role-based access control, and regulatory compliance readiness. The objective of this work was to evaluate and contrast existing security capabilities to inform secure adoption decisions in healthcare environments.

The benchmarking results demonstrate clear differentiation among platforms. OpenEMR and OSCAR EMR show the strongest authentication maturity, with native two-factor authentication, enforceable password policies, and comprehensive session controls. OpenMRS and Bahmni provide flexible, modular security architectures capable of achieving comparable authentication strength through extensions and external identity providers, while GNU Health exhibits more limited capabilities.

Across all platforms, encryption emerges as a critical and universal weakness. None of the evaluated EMRs provide native application-level encryption for data at rest or file attachments, and none offer integrated cryptographic key management or message-level encryption for HL7 or FHIR data exchange. This finding highlights a shared architectural gap in the open-source EMR ecosystem rather than shortcomings of individual platforms.

Interoperability security benchmarking identifies OpenMRS and Bahmni as the most capable systems due to comprehensive HL7/FHIR support and OpenHIM-based OAuth2-secured data exchange. OpenEMR and OSCAR EMR provide moderate interoperability security, while GNU Health offers more limited protections. However, all platforms rely primarily on transport-layer security, reinforcing the need for stronger end-to-end protection mechanisms.

Role-based access control capabilities are comparatively mature across most systems, particularly in OpenEMR, OpenMRS, Bahmni, and OSCAR EMR, which support fine-grained privilege models suitable for complex healthcare organizations. Regulatory compliance readiness varies, with OpenEMR and OSCAR EMR offering the strongest HIPAA-oriented technical safeguards and documentation, while other platforms depend more heavily on organizational configuration and governance.

Overall, this work contributes actionable, evidence-based insights. By clarifying the relative security strengths, limitations, and deployment dependencies of leading open-source EMR systems, the study supports healthcare organizations in selecting appropriate platforms, assists policymakers in understanding the security trade-offs of open-source adoption, and informs developers about priority areas for security improvement. These insights are particularly valuable for resource-constrained healthcare settings where informed

EMR selection and secure deployment are critical to patient safety and trust.

Future work can extend this research by broadening the scope of evaluation to include a larger set of open-source and proprietary EMR systems, enabling more comprehensive comparative insights. Additionally, the assessment framework can be enhanced by incorporating further dimensions such as usability, performance impact of security mechanisms, and incident response capabilities. From a technical perspective, there is a clear need for research into integrated application-level encryption, robust cryptographic key management, and advanced interoperability security mechanisms, including message-level protection. Further investigation into adaptive access control models and automated regulatory compliance support is also warranted.

References

- [1] S. R. Bagayoko et al. 2020. Open-source electronic health record systems for low-resource settings: systematic review. *JMIR Medical Informatics* 8, 6 (2020), e16978.
- [2] W. Barker et al. 2020. *Recommendation for Key Management*. Technical Report SP 800-57 Part 1 Rev. 5. NIST.
- [3] K. Barton et al. 2019. Encryption Vulnerabilities in Healthcare IT Systems. *IEEE Security & Privacy* 17, 5 (2019), 54–63.
- [4] C. Bender and C. Sartipi. 2013. HL7 FHIR: An Agile and RESTful Approach to Healthcare Information Exchange. In *Proceedings of the IEEE International Symposium on Computer-Based Medical Systems*. 326–331.
- [5] M. Bloomrosen et al. 2011. Use and adoption of health information exchange in the United States: Recent trends. *Journal of the American Medical Informatics Association* 18, 2 (2011), 129–135.
- [6] P. Bourgeois et al. 2020. The Impact of Encryption on Electronic Health Record System Performance. *Journal of the American Medical Informatics Association* 27, 4 (2020), 622–628.
- [7] DataGuard. 2024. *How Healthcare Companies Can Benefit from ISO 27001 Certification*. <https://www.dataguard.com/blog/how-healthcare-companies-can-benefit-from-iso-27001-certification>
- [8] T. Dierks and E. Rescorla. 2008. *The Transport Layer Security (TLS) Protocol Version 1.2*. Technical Report RFC 5246. IETF.
- [9] EMR Finder. 2024. *Healthcare EMR Cyber Security in 2024*. <https://emrfinder.com/blog/healthcare-emr-cyber-security-2024/>
- [10] J. L. Fernández-Alemán et al. 2013. Security and privacy in electronic health records: A systematic literature review. *Journal of Biomedical Informatics* 46, 3 (2013), 541–562.
- [11] D. F. Ferraiolo and D. R. Kuhn. 1992. Role-Based Access Control. In *Proceedings of the 15th National Computer Security Conference*. 554–563.
- [12] D. Hardt. 2012. *The OAuth 2.0 Authorization Framework*. Technical Report RFC 6749. IETF.
- [13] HL7 International. 2024. *FHIR Security*. <https://www.hl7.org/fhir/security.html>
- [14] IBM. 2025. *Cost of a Data Breach Report 2025*. <https://www.ibm.com/reports/data-breach>
- [15] International Organization for Standardization. 2022. *ISO/IEC 27001:2022 Information Security Management*. <https://www.iso.org/standard/27001>
- [16] Intraprise Health. 2024. *The Importance of the NIST Cybersecurity Framework in Healthcare*. <https://intraprisehealth.com/importance-of-the-nist-cybersecurity-framework-in-healthcare/>
- [17] J. Mandel et al. 2016. SMART on FHIR: A standards-based, interoperable apps platform. *Journal of the American Medical Informatics Association* 23, 5 (2016), 899–908.
- [18] D. M'Raihi et al. 2011. *TOTP: Time-Based One-Time Password Algorithm*. Technical Report RFC 6238. IETF.
- [19] National Institute of Standards and Technology. 2024. *Cybersecurity Framework*. <https://www.nist.gov/cyberframework>
- [20] Office for Civil Rights. 2019. *Cybersecurity Newsletter*.
- [21] Office of the Auditor General of Nova Scotia. 2024. *2024 Cybersecurity Readiness in Healthcare*. <https://oag-nb.ca/sites/default/files/2024-10/Interactive%202024%20Cybersecurity%20Readiness%20in%20Healthcare.pdf> Interactive Report.
- [22] Riddle Compliance. 2024. *HIPAA Compliance for Electronic Health Records*. <https://riddlecompliance.com/hipaa-compliance-for-electronic-health-records-ehrs/>
- [23] N. Sakimura et al. 2014. *OpenID Connect Core 1.0*. Technical Report. OpenID Foundation.
- [24] Scrut.io. 2024. *Healthcare Cybersecurity Frameworks*. <https://www.scrut.io/post/healthcare-cybersecurity-frameworks>
- [25] Trevor Stapenhurst. 2009. *The Benchmarking Book: A How-to Guide to Best Practice for Managers and Practitioners*. Elsevier.
- [26] U.S. Department of Health and Human Services. 2003. *HIPAA Security Rule*. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html> 45 CFR Parts 160, 162, and 164.
- [27] U.S. Department of Health and Human Services. 2024. *Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information*. https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf
- [28] R. Zhang and L. Liu. 2010. Security Models and Requirements for Healthcare Application Clouds. In *Proceedings of the IEEE 3rd International Conference on Cloud Computing*. 268–275.